Title of the Project :-

Enforce least-privilege access through identity- aware, application-specific access policies using Zscaler Private Access (ZPA)

Overview :-

With the rapid growth of cloud computing, remote work, and digital services, organizations are facing increasing cybersecurity threats. Traditional network security models rely on a perimeter-based approach where users inside the network are trusted automatically. Once attackers gain access to the internal network, they can move laterally and access sensitive resources without many restrictions. This makes traditional security architectures ineffective in modern environments.

To address these issues, many organizations are adopting the Zero Trust security model. The Zero Trust approach is based on the principle "Never Trust, Always Verify." Every user, device, and application must be authenticated and authorized before access to any resource is granted. This ensures that access decisions are made based on identity, device posture, and security policies rather than network location.

This project focuses on enforcing least-privilege access control using (ZPA). ZPA is a cloud-based Zero Trust Network Access solution that allows secure access to internal applications without exposing them to the public

internet. Instead of giving users full network access, ZPA connects users only to the specific applications they are authorized to use.

The main objective of this project is to implement identity-aware application access policies that limit user privileges and protect sensitive organizational resources. By restricting access to only necessary applications, organizations can significantly reduce the attack surface and prevent unauthorized access.

The project also includes vulnerability awareness and testing concepts aligned with the ** security guidelines. Understanding common web application vulnerabilities helps organizations identify weaknesses and implement stronger security controls.

Through this project, we gain knowledge about Zero Trust architecture, least-privilege access policies, identity-based authentication, and modern security solutions used to protect enterprise applications.

List of teammates–

S.no	***name***	***collage***	***contact***
1	JAYAPRATHAP.A	PPG COLLEGE OF ARTS AND SCIENCE	2322j0119.cas@ppg.edu.in
2	SUDHARSAN.M	PPG COLLEGE OF ARTS AND SCIENCE	2322j0138.cas@ppg.edu.in
3	SHARMI.P	PPG COLLEGE OF ARTS AND SCIENCE	2322j0136.cas@ppg.edu.in
4	SOWMIYA.R	PPG COLLEGE OF ARTS AND SCIENCE	2322j0137.cas@ppg.edu.in
5	SANJAI.N	PPG COLLEGE OF ARTS AND SCIENCE	2322j0135.cas@ppg.edu.in

List of Vulnerability Table —

S.no	***Vulnerability Name***	***CWE/CVE - No***
1	Absolute Path Traversal	CWE 36
2	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	CWE 614
3	Use of Unmaintained Third Party Components	CWE 1104

REPORT

Vulnerability Name - Broken Access Control

CWE / CVE -CWE-284

OWASP Category - A01: Broken Access Control

Description:-

Broken access control occurs when an application fails to properly enforce restrictions on authenticated users. Attackers may exploit this weakness to gain unauthorized access to resources such as sensitive data, administrative functions, or restricted services.

In traditional network environments, once users gain access to the internal network they may be able to reach multiple applications without strict access controls. This increases the risk of privilege escalation and unauthorized data access.

By implementing Zero Trust security using , organizations can enforce strict identity-based policies. Access is granted only after verifying user identity, device posture, and security rules. Instead

of granting full network access, users can only access specific applications required for their role.

This approach reduces the attack surface and prevents attackers from moving laterally within the network.

Business Impact

Broken access control vulnerabilities can allow attackers to gain unauthorized access to sensitive systems and confidential information. If exploited, this vulnerability may lead to data breaches, unauthorized modification of data, and exposure of critical business resources. Organizations may suffer financial loss, reputational damage, and legal consequences due to security incidents. Implementing Zero Trust security and least-privilege access policies helps reduce these risks and ensures that only authorized users can access protected applications.